

Incident Response Report & Kill-Chain Timeline

INC-2026-002 — Simulated Multi-Stage AWS Cloud Compromise

Classification: Simulated / Controlled Attack Emulation (Purple Team Exercise) **Environment:** AWS Free Tier Lab, Account `tahmid-admin` (us-east-1) **Framework Alignment:** NIST SP 800-61 Rev. 2, MITRE ATT&CK v15 (Cloud Matrix) **Prepared by:** Tahmid Abtahee **Date:** [DATE]

1. Executive Summary

This report documents a simulated five-stage attack chain executed against an isolated AWS free-tier environment as part of a hybrid on-prem/cloud threat detection lab. The exercise used Stratus Red Team v2.33.0 to detonate adversary techniques spanning Initial Access, Discovery, Persistence, Credential Access, and Defense Evasion. All activity was captured via AWS CloudTrail, ingested into Splunk through an SQS-based S3 input pipeline, and detected using five custom Sigma rules authored and converted with sigma-cli (Splunk backend).

The objective was to validate detection coverage across a realistic cloud attack progression and produce native SIEM detections without relying on managed cloud alerting (e.g., GuardDuty), demonstrating detection engineering capability rather than dependency on vendor tooling.

Outcome: All five techniques were successfully detected and validated in Splunk. One false-positive source was identified and tuned out during the Discovery stage (see Section 6).

2. Environment & Detection Stack

Component	Detail
Cloud Provider	AWS (Free Tier), region us-east-1

Component	Detail
Log Source	AWS CloudTrail (multi-region trail: <code>tahmid-threat-lab-trail</code>)
Log Delivery	CloudTrail → S3 (<code>tahmid-threat-lab-cloudtrail-logs</code>) → SQS (<code>tahmid-threat-lab-cloudtrail-queue</code>) → Splunk
SIEM	Splunk Enterprise 10.4.0, Splunk Add-on for AWS
Index	<code>aws_cloudtrail</code>
Detection Authoring	Sigma rules, converted via <code>sigma convert -t splunk --without-pipeline</code>
Attack Emulation	Stratus Red Team v2.33.0, executed from Kali Linux (<code>kali-attacker</code>)
Enrichment	Python (<code>enrich.py</code>) — boto3/requests, IP reputation via AbuseIPDB/OTX, Slack/email alerting
IaC	Terraform (<code>~/threat-lab-terraform</code>) — CloudTrail, S3, SQS/DLQ

Note on GuardDuty: GuardDuty was deliberately not enabled for this exercise. The architecture was designed to support GuardDuty as a managed-detection layer, but detections were implemented natively in Splunk to demonstrate hand-built detection engineering rather than relying on AWS's out-of-the-box alerting.

3. Kill Chain Timeline

Timestamps below are placeholders — replace with exact `_time` values from Splunk (`index=aws_cloudtrail`) for each stage.

Stage 1 — Initial Access

Technique: `aws.initial-access.console-login-without-mfa` **ATT&CK:** T1078.004 (Valid Accounts: Cloud Accounts) **Time:** [TIMESTAMP 1]

Simulated an AWS Console login without MFA enforced, representing a credential-based initial foothold into the environment.

- **CloudTrail Event:** `ConsoleLogin`
- **Detection:** Sigma rule — single-event tripwire on `eventName=ConsoleLogin` with `additionalEventData.MFAUsed=No`
- **Result:** Detected. Alert fired on first matching event.

Stage 2 — Discovery

Technique: `aws.discovery.ec2-enumerate-from-instance` **ATT&CK:** T1580 (Cloud Infrastructure Discovery) / T1087 (Account Discovery) **Time:** [TIMESTAMP 2]

Simulated enumeration of EC2 resources from within a compromised instance context, consistent with post-access reconnaissance.

- **CloudTrail Events:** Multiple `Describe*/List*` API calls
- **Detection:** Sigma rule — volume/variety aggregation on distinct `Describe*/List*` calls from a single identity within a short window
- **False Positive Note:** `AWSServiceRoleForResourceExplorer` generated legitimate background `List*/Describe*` calls that initially inflated results. Filtered using `NOT userIdentity.arn="*:assumed-role/AWSServiceRoleFor*"` to isolate attacker-originated calls. See Section 6.
- **Result:** Detected after FP tuning.

Stage 3 — Persistence

Technique: `aws.persistence.iam-create-admin-user` **ATT&CK:** T1136.003 (Create Account: Cloud Account) **Time:** [TIMESTAMP 3]

Simulated creation of a new IAM user with administrator-level privileges, establishing persistent access independent of the initially compromised credential.

- **CloudTrail Events:** `CreateUser`, `AttachUserPolicy` (AdministratorAccess)
- **Detection:** Sigma rule — correlated sequence detection linking `CreateUser` → `AttachUserPolicy` with an admin-scoped policy ARN within a bounded time window
- **Result:** Detected. High-confidence correlated alert.

Stage 4 — Credential Access

Technique: `aws.credential-access.secretsmanager-batch-retrieve-secrets`

ATT&CK: T1555 (Credentials from Password Stores) / T1552 (Unsecured Credentials) **Time:** [TIMESTAMP 4]

Simulated bulk retrieval of secrets from AWS Secrets Manager, representing an attempt to harvest stored credentials for lateral movement or further access.

- **CloudTrail Events:** `BatchGetSecretValue` / `GetSecretValue`
- **Detection:** Sigma rule — rate-threshold detection on secret-retrieval calls exceeding a defined count per identity per time window
- **Result:** Detected.

Stage 5 — Defense Evasion

Technique: `aws.defense-evasion.cloudtrail-stop` **ATT&CK:** T1562.008 (Impair Defenses: Disable Cloud Logs) **Time:** [TIMESTAMP 5]

Simulated an attempt to disable CloudTrail logging to blind detection and cover further attacker activity — the final stage of the chain, targeting the logging pipeline itself.

- **CloudTrail Event:** `StopLogging`
 - **Detection:** Sigma rule — single critical-event type, zero-tolerance alert on any `StopLogging` call regardless of actor
 - **Result:** Detected immediately. Treated as highest-severity alert in the chain (logging disablement should never be a false positive in this environment).
-

4. NIST SP 800-61 Incident Response Phases

4.1 Preparation

- Multi-region CloudTrail trail, S3 log storage, and SQS-based delivery pipeline provisioned via Terraform prior to exercise.
- Splunk AWS Add-on configured with dedicated `aws_cloudtrail` index.

- Five Sigma detections authored and validated against expected CloudTrail field schemas before detonation (no custom pipeline required — raw CloudTrail fields matched Sigma's generic taxonomy directly).
- Zero-spend AWS budget alert configured to prevent unexpected cost during testing.

4.2 Detection & Analysis

- All five techniques detonated sequentially using Stratus Red Team.
- Each stage cross-verified in Splunk against both raw CloudTrail events and Sigma-converted SPL detections.
- Analysis confirmed a complete, chronologically consistent attack narrative from initial access through defense evasion.

4.3 Containment

- Exercise conducted in an isolated free-tier account with no production resources, limiting blast radius by design.
- In a live scenario, containment actions would include: disabling the newly created IAM admin user, revoking active sessions for the initial-access identity, and re-enabling/verifying CloudTrail logging immediately upon detection of **StopLogging**.

4.4 Eradication & Recovery

- All Stratus Red Team techniques were cleaned up (**stratus cleanup**) post-detonation, reverting IAM changes and removing test artifacts.
- CloudTrail logging state verified as active following the Stage 5 simulation.
- No persistent unauthorized access remained in the environment post-exercise.

4.5 Post-Incident Activity / Lessons Learned

- Confirmed native Sigma-based detection coverage is achievable across a full cloud kill chain without managed alerting (GuardDuty).
 - Identified and resolved a real false-positive source (service-linked role enumeration noise) — a transferable tuning lesson for any AWS discovery-stage detection.
 - Validated that raw CloudTrail fields align with Sigma's generic cloud taxonomy, simplifying rule portability.
-

5. Detection Summary Table

Stage	ATT&CK Technique	Stratus Technique ID	Sigma Detection Type	Result
Initial Access	T1078.004	<code>aws.initial-access.console-login-without-mfa</code>	Single-event tripwire	Detected
Discovery	T1580 / T1087	<code>aws.discovery.ec2-enumerate-from-instance</code>	Volume/variety aggregation	Detected (post-tuning)
Persistence	T1136.003	<code>aws.persistence.iam-create-admin-user</code>	Correlated sequence	Detected
Credential Access	T1555 / T1552	<code>aws.credential-access.secretsmanager-batch-retrieve-secrets</code>	Rate threshold	Detected
Defense Evasion	T1562.008	<code>aws.defense-evasion.cloudtrail-stop</code>	Single critical-event	Detected

6. False Positive Tuning Note

During the Discovery stage, the service-linked role `AWSServiceRoleForResourceExplorer` generated legitimate `List*/Describe*` API calls unrelated to the simulated attacker activity, which initially inflated the aggregation detection's result set.

Resolution: Added an exclusion filter — `NOT userIdentity.arn="*:assumed-role/AWSServiceRoleFor*"` — to isolate attacker-originated identity activity from routine AWS service background noise.

Takeaway: Cloud environments generate continuous service-to-service API activity from AWS-managed roles. Any discovery/enumeration detection built on raw API call volume must explicitly exclude known service-linked role patterns, or it will produce persistent low-fidelity alerts that erode analyst trust in the detection.

7. Recommendations

- Enable GuardDuty in a production equivalent of this environment as a defense-in-depth layer alongside native Sigma detections, rather than as a replacement for them.
 - Extend the `AWSServiceRoleFor*` exclusion pattern into a maintained allowlist as new AWS-managed service roles are introduced.
 - Add automated response actions (e.g., auto-disable IAM user, auto-enable CloudTrail) triggered directly from Splunk alerts for the Persistence and Defense Evasion stages, given their zero-tolerance severity.
-

Appendix A — IOCs / Identifiers

Type	Value
CloudTrail Trail	<code>tahmid-threat-lab-trail</code>
S3 Log Bucket	<code>tahmid-threat-lab-cloudtrail-logs</code>
SQS Queue	<code>tahmid-threat-lab-cloudtrail-queue</code>
DLQ	<code>tahmid-threat-lab-cloudtrail-dlq</code>

Type	Value
Splunk Index	<code>aws_cloudtrail</code>
IAM Persistence Artifact	Newly created IAM user with <code>AdministratorAccess</code> (removed post-exercise)

Appendix B — Tooling

- Stratus Red Team v2.33.0
- sigma-cli v3.0.3 (Splunk backend plugin, via pipx)
- Splunk Add-on for AWS
- Terraform (AWS provider)